

1. Наиболее рискованные пользователи

1. Заместитель директора по безопасности (сотрудник 12)
 - 1) Отправил человеку не из компании через личный аккаунт в ВК таблицу с информацией о имеющейся в собственности компании продукции (разглашение коммерческой тайны; вполне возможно, что и экономический шпионаж).
 - 2) Пароль доменной учётной записи этого сотрудника не отвечает требованиям политики информационной безопасности — выдвину предположение: учётная запись скомпрометирована. Скорее всего, что у этого сотрудника в домене наивысшие права доступа. Второй фактор аутентификации мог настроить уже злоумышленник на подконтрольный ему аутентификатор.
2. Специалист технической поддержки (сотрудник 20)

Если накопитель не является корпоративным (учтённый) и политически такое копирование запрещается, то возникли нарушения порядка обработки персональных данных, которые к тому же составляют врачебную тайну.
3. Аккаунт-менеджер (сотрудник 42)

Через личный аккаунт в социальной сети в раздел «Избранное» передана таблица, содержащая 254 учётные записи (адрес почты и пароль) к личному кабинету МИС. Передача аутентификационных данных во внешний сервис нарушает установленный порядок обращения с учётными данными и создаёт условия для несанкционированного доступа к сведениям, составляющим врачебную тайну.
4. Управляющий филиалом (сотрудник 34)

В публичный ИИ-сервис выгружена таблица с полными финансовыми и операционными показателями медицинского центра за два года, включая фонд оплаты труда врачей. Компания не контролирует дальнейшую обработку переданных данных и не располагает гарантиями их неразглашения, поэтому сведения, составляющие коммерческую тайну, следует считать раскрытыми третьим лицам.
5. Специалист по отменам записей (сотрудник 43)

В чат социальной сети с пятью участниками направлена таблица с персональными данными пациентов и сведениями о назначенных процедурах. Допущено разглашение сведений, составляющих врачебную тайну, и нарушен порядок обработки персональных данных.
6. Аналитик данных (сотрудник 30)

В публичный ИИ-сервис передана сводная таблица по выручке, маржинальности и себестоимости медицинских услуг по всей сети клиник. Раскрыт консолидированный массив сведений, составляющих коммерческую тайну, в объёме, позволяющем оценить экономику всего бизнеса.
7. Директор филиала (сотрудник 25)

В публичный ИИ-сервис выгружена таблица на 691 строку с данными по направлениям услуг, марже и выручке. Нарушение допущено руководителем филиала, что помимо раскрытия коммерческой тайны создаёт прецедент для подчинённых.

8. Бухгалтер (сотрудник 38)

Оборотно-сальдовая ведомость по одному из юридических лиц передана в публичный ИИ-сервис, а затем загружена в личный кабинет вуза в качестве отчёта по практике. Бухгалтерские сведения последовательно раскрыты в двух внешних системах, контроль над их дальнейшим распространением утрачен.

9. Функциональный архитектор (сотрудник 10)

В личном облачном хранилище под неучётной учётной записью размещена структурированная копия внутренних материалов компании: описания функционала сервисов МИС и финансовые таблицы. Это не разовая передача, а постоянное хранение сведений за пределами контролируемого периметра, организованное через установленный на рабочем месте клиент синхронизации.

10. Маркетолог (сотрудник 19)

В Telegram-чат с семью участниками, не оборудованный корпоративным ботом контроля, направлена таблица на 6409 строк с себестоимостью медицинских исследований. Раскрыт значительный по объёму массив сведений, составляющих коммерческую тайну, причём состав получателей компанией не контролируется.

11. Специалист чат-поддержки (сотрудник 32)

Работа велась в общедоступной облачной таблице, содержащей номера телефонов пациентов, даты и описания их обращений. Персональные данные размещены в открытом доступе, порядок их обработки нарушен, доступ к ним имеет неограниченный круг лиц.

12. Учётник расходников (сотрудник 8)

В Telegram-чат с пятью участниками направлена таблица с действующими логином и паролем от учётной записи в Active Directory и корпоративном сервисе Google Workspace. Созданы условия для несанкционированного доступа к корпоративным ресурсам от имени этого сотрудника.

2. Повторяющиеся нарушения

Нарушение	Количество	События
Утечка коммерческой информации (выручка, маржа, себестоимость, закупочные цены, остатки, бухгалтерская отчётность)	12	1, 2, 5, 9, 16, 17, 19, 25, 27, 30, 34, 38
Поиск работы (не всегда является нарушением)	7	3, 4, 6, 29, 36, 37, 39
Персональные данные сотрудников и пациентов, врачебная тайна	5	7, 15, 20, 32, 43
Финансовая уязвимость: долги в МФО, ставки	4	21, 22, 33, 40
Выгрузка данных компании в публично-доступную нейронную сеть DeepSeek	4	25, 30, 34, 38
Применение нерегламентированных программ	4	18 (торрент), 23 (VPN), 26 (непроверенный образ), 41 (кликер)
Слабые пароли доменных учётных записей	4	11, 12, 13, 14
Утечка учётных данных (логины и пароли от корпоративных ресурсов)	3	8, 35, 42
Корпоративные данные в личных облаках и открытых таблицах	3	10, 31, 32

3. Основные каналы утечки

Канал	Количество	События	Данные
Мессенджер (Telegram)	8	1, 7, 8, 9, 16, 17, 19, 35	выручка, маржа, себестоимость, закупочные цены; премии медперсонала; логины и пароли
Социальная сеть (VK)	6	2, 5, 15, 27, 42, 43	выручка, маржа, остатки, внутренние документы, персональные данные сотрудников и пациентов, 254 учётные записи МИС
Публично-доступные нейронные сети (DeepSeek)	4	25, 30, 34, 38	полные финансовые показатели филиалов и всей сети, оборотно-сальдовая ведомость
Облачный пакет офисных программ (Яндекс Диск, Яндекс Таблицы)	3	10, 31, 32	описания МИС и финансовые таблицы; обращения в госорганы; телефоны и жалобы пациентов
Съёмный носитель (USB-флешка)	1	20	персональные данные пациентов, сканы паспортов, медицинская документация
Личная электронная почта	1	24	регламент работы операторов

4. Рекомендации

Направление	Мера	Основание (события)	Срок
Реагирование на инциденты	Сменить пароли и завершить сессии скомпрометированных учётных записей, по МИС — сбросить 254 записи и уведомить партнёров	8, 35, 42	1–7 дней
	Проверить учётную запись зам. директора по безопасности и владельца второго фактора, ограничить права	12, 27	1–7 дней
	Установить личность получателей, которых нет среди сотрудников компании	9, 27	1–7 дней
	Проверить съёмный накопитель, зафиксировать состав скопированных данных	20	1–7 дней
	Оценить необходимость уведомления Роскомнадзора об утечке персональных данных; информации, составляющей врачебную тайну	20, 32, 43	1–7 дней
	Закрыть публичный доступ к облачным таблицам и удалить данные компании из личного облака	10, 31, 32	1–7 дней
Мессенджеры, социальные сети	Запретить передачу файлов через личные аккаунты мессенджеров и соцсетей на рабочих станциях (АРМ)	1, 2, 5, 7, 15, 35, 42, 43	1 месяц
	Перевести рабочие переписки в корпоративный мессенджер, включить бота контроля во всех рабочих чатах	1, 8, 16, 17, 19, 43	1 месяц
Нейронные сети	Заблокировать доступ к публично-доступным нейронным сетям	25, 30, 34, 38	1 месяц
	Развернуть разрешённый корпоративный ИИ-контур как замену публичным сервисам	25, 30, 34, 38	3 месяца
Облака и носители	Блокировать клиенты синхронизации личных облаков (yandexdisk2.exe) и домены личных хранилищ	10, 31, 32	1 месяц
	Разрешить запись только на учтённые зашифрованные носители, вести журнал подключений	20, 26	1 месяц
	Запретить отправку рабочих вложений и ссылок на личные	24, 39	1 месяц

Направление	Мера	Основание (события)	Срок
	почтовые адреса		
Рабочие места	Убрать права локального администратора и вести список разрешённого ПО	18, 23, 26, 41	3 месяца
Учётные записи и права	Ужесточить парольную политику, проверять пароли по базам утечек, принудительно сменить	11, 12, 13, 14	1 месяц
	Включить второй фактор аутентификации для всех учётных записей, в первую очередь привилегированных	8, 12, 35	1 месяц
	Пересмотреть права по принципу минимальных полномочий: ОВК, техподдержка, архитектор	10, 12, 20	3 месяца
	Ограничить массовые выгрузки из МИС и учётных систем: лимит строк, согласование, журналирование	17, 19, 27, 42	3 месяца
Работа с персоналом	Ввести повышенный мониторинг сотрудников в поиске работы и проверку выгрузок при увольнении	3, 4, 6, 29, 36, 37, 39	1 месяц
	Пересмотреть доступ к массивам данных у сотрудников с долговой нагрузкой и ставками	21, 22, 33, 40	1 месяц
	Применять дисциплинарные меры к повторным нарушителям	12, 33, 40, 41	постоянно
	Обучать на обезличенных случаях отчёта, отдельно инструктировать руководителей	1, 17, 25, 34	ежеквартально